Outline

- Causes of vulnerabilities
- Cybersecurity vulnerabilities
- Impact of vulnerabilities
- Vulnerability assessment process
- Methods of vulnerability detection
- Top vulnerability scanning tools
- CVE, CVSS, CNA and CVSS
- Vulnerability scanning and penetration testing
- Vulnerability management
- Vulnerability management components
- Software patch and types of software patching
- Why is patch management important?

Causes Vulnerabilities

Causes Vulnerabilities

There are many causes of vulnerabilities, including:

i) Complexity - Complex systems increase the probability of a flaw, misconfiguration, or unintended access.

ii) Familiarity - Common code, software, operating systems, and hardware increase the probability that an attacker can find or has information about known vulnerabilities.

iii) Connectivity - The more connected a device is, the higher the chance of a vulnerability.

iv) Poor Password Management - Weak passwords can be broken with brute force, and reusing passwords can result in one data breach becoming many.

v) Operating System Flaws - Like any software, operating systems can have flaws. Operating systems that are insecure by default allow any user to gain access and potentially inject viruses and malware.

Causes Vulnerabilities……

vi) Internet Usage - The Internet is full of spyware and adware that can be installed automatically on computers.

vii) Software Bugs - Programmers can accidentally or deliberately leave an exploitable bug in software. Sometimes end users fail to update their software, leaving them unpatched and vulnerable to exploitation.

viii) Unchecked User Input - If your website or software assumes all input is safe, it may execute unintended SQL commands.

ix) People - The biggest vulnerability in any organization is the human at the end of the system. Social engineering is the biggest threat to the majority of organizations. This category of cyber threats can be addressed with an in-house cyber threat awareness program.

Cybersecurity Vulnerabilities

Cybersecurity Vulnerabilities

i) Zero Day

Zero days are specific software security vulnerabilities known to the adversary but for which no fix is available, often because the bug has not been reported to the vendor of the vulnerable system.

ii) Remote Code Execution (RCE)

An RCE vulnerability allows an attacker to execute malicious code on the vulnerable system. This code execution can allow the attacker to steal sensitive data, deploy malware, or take other malicious actions on the system.

iii) Poor Data Sanitization

Many attacks — such as SQL injection and buffer overflows — involve an attacker submitting invalid data to an application. A failure to properly validate data before processing leaves these applications vulnerable to attack.

Cybersecurity Vulnerabilities….

iv) Unpatched Software

Software vulnerabilities are common, and they are corrected by applying patches or updates that fix the issue. A failure to properly patch out-of-date software leaves it vulnerable to exploitation.

v) Unauthorized Access

It is common for companies to assign employees and contractors more access and privileges than they need. These additional permissions create security risks if an employee abuses their access or their account is compromised by an attacker.

vi) Misconfiguration

Software commonly has various configuration settings that enable or disable different features, including security functionality. A failure to configure applications securely is a common problem, especially in cloud environments.

Cybersecurity Vulnerabilities….

vii) Credential Theft

Cybercriminals have different means of stealing user credentials, including phishing, malware, and credential stuffing attacks.

viii) Vulnerable APIs

Often, web security strategies focus on web applications, which are the more visible components of a corporate digital attack surface. However, APIs can be even more damaging if not properly secured against unauthorized access or exploitation.

ix) Malicious Insider

An employee or a vendor who might have access to your critical systems can decide to exploit their access to steal or destroy information or impair them. This is particularly important for privileged users and critical systems.

x) Missing/Poor Encryption

With attacks on Missing/Poor Encryption, an attacker can intercept communication between systems in your network and steal information.

Impact of Vulnerabilities

Impact of Vulnerabilities

The exploitation of these vulnerabilities can lead to various security breaches and attacks:

- **Data Breach**: Unauthorized access to confidential data.

- **System Compromise**: Complete takeover of the operating system, leading to loss of control over system functionalities.

- **Malware Spread**: Use of vulnerabilities to spread malware, ransomware, or other malicious software.

Vulnerability assessment process & detection

Vulnerability assessment process

1. Identify Vulnerabilities

Analyzing network scans, pen test results, firewall logs, and vulnerability scan results to find anomalies that suggest a cyber attack could take advantage of a vulnerability.

2. Verify Vulnerabilities

Decide whether the identified vulnerability could be exploited and classify the severity of the exploit to understand the level of risk.

3. Mitigate Vulnerabilities

Decide on countermeasures and how to measure their effectiveness if a patch is unavailable.

4. Remediate Vulnerabilities

Remediating vulnerabilities requires updating affected software or hardware where possible.

Mitigation includes reducing the impact of a threat when it cannot be eliminated. Remediation completely removes the threat when it's possible.

Methods of vulnerability detection

- **Vulnerability scanning**: It is the process of discovering, analyzing, and reporting on security flaws and vulnerabilities.

- **Penetration testing**: Penetration testing (or pen testing or ethical hacking) is a security exercise where a cyber-security expert attempts to find and exploit vulnerabilities in a computer system.

- **Google hacking**: Google hacking, sometimes, referred to as Google *dorking*, is an information gathering technique used by an attacker leveraging advanced Google searching techniques. Google hacking search queries can be used to identify security vulnerabilities in web applications.

Vulnerability Scanning

- **Vulnerability scanning** is the process of discovering, analyzing, and reporting on security flaws and vulnerabilities.

- **Vulnerability scans** are conducted via automated vulnerability scanning tools to identify potential risk exposures and attack vectors across an organization’s networks, hardware, software, and systems.

- **Vulnerability scanning** and assessment is an essential step in the vulnerability management lifecycle.

Credentialed Scans vs. Non-Credentialed Scans

Credentialed (**authenticated**) scans and non-Credentialed (**non-authenticated**) scans are the two main categories of vulnerability scanning.

- **Non-credentialed scans**, do not require credentials and do not get trusted access to the systems they are scanning. While they provide an outsider's eye view of an environment, they tend to miss most vulnerabilities within a target environment.

- **Credentialed scans** require logging in with a given set of credentials. These authenticated scans are conducted with a trusted user's eye view of the environment. Credentialed scans uncover many vulnerabilities that traditional (non-credentialed) scans might overlook.

Top vulnerability scanning tools

- **Tenable:** Best overall vulnerability scanner and enterprise vulscan option
- **Invicti:** Best for comprehensive website and application (webapp) scans
- **StackHawk:** Best entry-level webapp scanner for small DevOps teams
- **Nmap:** Best open-source tool for free IT infrastructure and port scanning
- **ConnectSecure:** Best basic infrastructure scanning for service providers
- **Vulnerability Manager Plus:** Best entry-level endpoint and server scanner
- **Wiz:** Best specialist tool for clouds, containers, and infrastructure as code

Penetration testing/ethical hacking

- Penetration testing, also known as pen testing or ethical hacking, is the practice of testing an information technology asset to find security vulnerabilities an attacker could exploit.
- Penetration testing can be automated with software or performed manually. Either way, the process is to gather information about the target, identify possible vulnerabilities and attempt to exploit them, and report on the findings.
- Penetration testing may also be used to test an **organization's security policy, adherence to compliance requirements, employee security awareness,** and an organization's ability to identify and respond to security incidents.
- VAPT- vulnerability assessment and penetration testing usually carried out regularly in important organization after a fixed interval of time.

Vulnerability Scanning vs Penetration Testing

Vulnerability scanning and penetration testing are both methods by which an organization's security team can find weaknesses in its cybersecurity. However, these two methods are very different.

- A ***vulnerability scan*** is an automated search for known vulnerabilities. A number of different vulnerability scanners exist, and they operate by searching for signatures of known vulnerabilities or common security errors (such as the use of weak passwords). These scans are typically designed to **find high-level weaknesses** within an organization's applications and IT infrastructure.

- A ***penetration test*** is an assessment of an organization's cybersecurity by a human operator or team or automated to some extend. This provides a more in-depth assessment because the penetration testers will actually exploit identified vulnerabilities, enabling them to gain additional access to the **target network and identify internal issues in the network**. Additionally, penetration testers can test potential attack vectors outside the scope of a vulnerability assessment, such as social engineering and phishing attacks.

Vulnerability assessment vs Penetration Testing

Feature	Vulnerability Assessment (VA)	Penetration Testing
Focus	Identifies potential vulnerabilities and prioritizes them based on severity.	Attempts to exploit vulnerabilities to understand their actual impact and potential for compromise.
Usage of Tools	Heavily relies on automated vulnerability scanners	Primarily uses skilled security experts. Tools may be used for initial discovery or specific tasks.
Performed By	Largely automated by vulnerability scanning tools.	Conducted by experts with deep knowledge of hacking techniques and system security.
Depth	Offers a broad overview of potential weaknesses.	Provides a deeper understanding of exploitable vulnerabilities.
Automation	Highly automated, allowing for frequent and quick scans.	Limited automation. Requires manual intervention to analyze results, exploit vulnerabilities, and assess impact.
Frequency	Can be performed very frequently (daily or weekly) depending on risk tolerance.	Typically performed monthly, quarterly, or annually, depending on security needs.
Compliance	Can be used for continuous compliance monitoring	Mandatory for compliance pentests such as GDPR, HIPAA, ISO, CERT-IN, and SOX
Certification	Does not directly lead to a penetration testing certification.	Can be used to prepare for and demonstrate skills required for penetration testing certifications.
Outcome	Provides a report listing vulnerabilities and their severity levels.	Provides a report detailing exploited vulnerabilities, the attacker's path to compromise, and potential remediation strategies.
Cost	Lower cost due to automation.	Higher cost due to skilled personnel required.

Penetration testing tools

- vPenTest
- Metasploit
- BreachLock Penetration Testing as a Service
- Edgescan
- NetSPI Penetration Testing Services
- Astra

CVE, CNA and CVSS

CVE: Common Vulnerabilities and Exposures

- CVE stands for Common Vulnerabilities and Exposures. CVE Program's primary purpose is to uniquely identify vulnerabilities and to associate specific versions of code bases to those vulnerabilities.

- An exposure is a mistake that gives an attacker access to a system or network. Exposures can lead to data breaches, data leaks.

- The goal of CVE is to make it easier to share information about known vulnerabilities so that cybersecurity strategies can be updated with the latest security flaws and security issue.

- A CVE score is often used for prioritizing the security of vulnerabilities.

- Founded in 1999, the CVE program is maintained by the MITRE corporation and sponsored by the U.S. Department of Homeland Security (DHS) and the Cybersecurity and Infrastructure Security Agency (CISA) as well as US-CERT.
- **MITRE** is a not-for-profit **corporation** committed to the public interest, operating federally funded R&D centers on behalf of U.S. government sponsors.

What are CNAs?

- CVE Numbering Authorities (CNAs) are organizations that identify and distribute CVE ID numbers to researchers and vendors for inclusion in public announcements of new vulnerabilities.

- CNAs include software vendors, open source projects, coordination centers, bug bounty service providers and research groups. **Bug bounty** programs offer monetary rewards to ethical hackers for successfully discovering and reporting a vulnerability or bug to the application's developer.

- CNAs are a federated systems that helps identify vulnerabilities and assigns them an ID without directly involving MITRE which is the primary CNA.

- There are currently 104 CNAs in 18 countries including many household names like Microsoft, Adobe, Apple, Cisco, Google, Hewlett Packard Enterprise, Huawei, IBM, Intel, Mozilla, Oracle, Red Hat, Siemens, Symantec, VMWare, Atlassian, Autodesk, Cloudflare, Elastic, GitHub, Kubernetes, Netflix and Salesforce etc.

How is a Vulnerability or Exposure Added to CVE?

- CVEs are added when a researcher finds a flaw or design oversight in software or firmware. The vendor does not have to see it as a vulnerability for it to be listed as a CVE- the researcher require to provide evidence of how it could be used as part of an exploit.

- Potential CVEs reported by established vendors or other trusted parties will generally be added to the CVE list quickly.

- CVE is a list of publicly disclosed vulnerabilities and exposures that is maintained by MITRE. NVD – The National Vulnerability Database (NVD) is a database, maintained by NIST, that is fully synchronized with the MITRE CVE list.
- A CVE entry describes a known vulnerability or exposure. Each CVE entry contains a standard identifier number with status indicator (*i.e.* "CVE-1999-0067", "CVE-2014-12345", "CVE-2016-7654321"), a brief description and references related vulnerability reports and advisories.

Vulnerability metric: Common Vulnerability Scoring System (CVSS)

- The Common Vulnerability Scoring System (CVSS) is a method used to supply a qualitative measure of severity. **CVSS is not a measure of risk.** CVSS v2.0 and CVSS v3.x consist of three metric groups: Base, Temporal, and Environmental.
- The Temporal score considers how those **characteristics may change over time**. The Environmental score evaluates how the **vulnerability could affect a specific environment.**

- CVSS is a set of open standards for assigning a number to a vulnerability to assess its severity. CVSS scores are used by the national vulnerability database (NVD), CERT, UpGuard and others to assess the impact of a vulnerability.

- A CVSS score ranges from 0.0 to 10.0. The higher the number the higher degree of security severity.

Common Vulnerability Scoring System (CVSS)

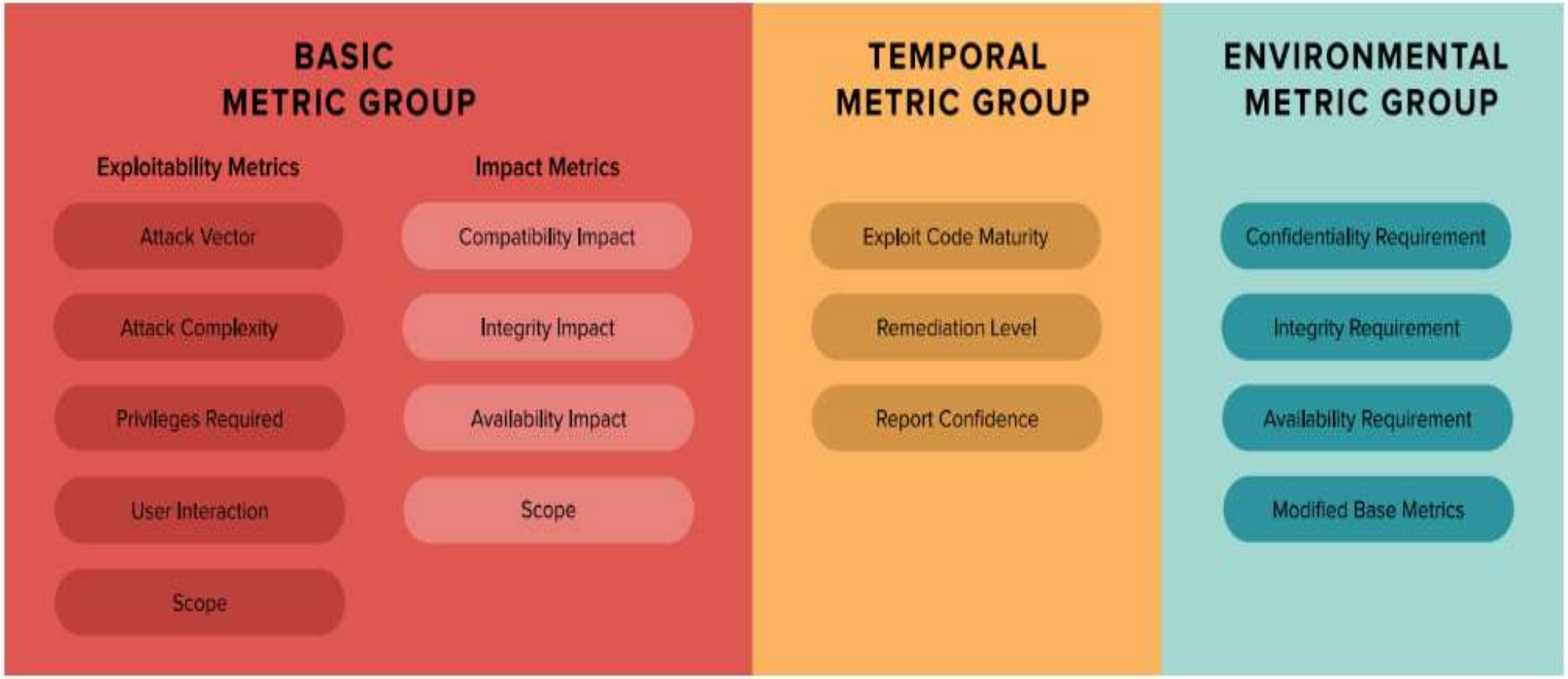
- CVSS is well suited as a standard measurement system for industries, organizations, and governments that need accurate and consistent vulnerability severity scores.

- Two common uses of CVSS are calculating the severity of vulnerabilities discovered on one's systems and as a factor in prioritization of vulnerability remediation activities.

- The National Vulnerability Database (NVD) provides CVSS enrichment for all published CVE records.
- The NVD supports Common Vulnerability Scoring System (CVSS) v2.0, v3.x and v4.0 standards.

CVSS score metric

A CVSS score is composed of three sets of metrics (**Base**, **Temporal**, **Environmental**), each of which have an underlying scoring component.



CVSS Base Metrics

The Base Metrics are the core components used to determine how severe a security vulnerability is.

They focus on the vulnerability's characteristics, regardless of whether it has been exploited or mitigated. These metrics include:

- Exploitability,
- Scope, and
- Impact.

Exploitability:

This metric assesses how easily a vulnerability is exploited. It is broken down into four sub-components:

- **Attack Vector**: Measures how an attack can be executed, with higher scores for remote attacks versus those requiring physical access.
- **Attack Complexity**: Evaluate the difficulty of executing the attack, with lower scores for easier vulnerabilities to exploit.
- **Privileges Required**: This indicator indicates the level of access needed to exploit the vulnerability, with higher scores for attacks requiring fewer privileges.
- **User Interaction**: Considers whether the attacker needs to involve a user in the exploit, with autonomous attacks scoring higher.

Scope

- This metric assesses whether the vulnerability can affect other components beyond the initial target.

- The score will be higher if the vulnerability can propagate, such as compromising an entire system through a single application flaw.

Impact

This metric evaluates the potential consequences of a successful exploit, focusing on three areas:

- **Confidentiality**: Measures the extent of data exposure.

- **Integrity**: Assesses the ability of the attacker to modify data.

- **Availability**: Evaluate the potential disruption to system access and functionality.

Limitations of Base metrics

- While CVSS-based Base Metrics provide a crucial starting point for understanding a vulnerability's severity, they have limitations.
- They do not account for Temporal Metrics, which change over time, or Environmental Metrics, which reflect an organization's specific context, such as existing security controls and asset criticality.
- Organizations must consider these additional factors to fully assess and prioritize vulnerabilities, which can significantly alter the perceived risk and required response.

CVSS Temporal Metrics

CVSS Temporal Metrics evaluate the changing nature of a vulnerability over time. These metrics assess a vulnerability's current exploitability and the availability of remediating controls, such as patches. Key sub=components of Temporal Metrics include:

- **Exploit Code Maturity**: A vulnerability is less threatening until a method to exploit it becomes available. As exploit code matures and becomes more widespread, its associated score increases, reflecting the heightened risk.
- **Remediation Level**: A vulnerability may not initially have a patch or workaround. As temporary fixes or official patches are released, the vulnerability score decreases, indicating reduced risk.
- **Report Confidence**: This measures how well a vulnerability is validated, ensuring it is both real and exploitable—higher confidence results in a higher score.

CVSS Environmental Metrics

CVSS Environmental Metrics allow organizations to adjust the Base CVSS score based on their specific Security Requirements and modifications of Base Metrics.

- **Security Requirements**: These metrics consider the criticality of the affected asset. Mission-critical systems, like a database containing all customer data, receive higher scores than less critical assets, such as a non-privileged user's workstation.
- **Modified Base Metrics**: Organizations can modify Base CVSS Metrics based on existing mitigations. For instance, "air gapping" a server—disconnecting it from external networks—lowers the Attack Vector score since remote exploitation is no longer possible.

By considering both Temporal and Environmental Metrics, organizations can achieve a more tailored and accurate assessment of a vulnerability's actual risk to their specific environment.

Qualitative Severity Ratings

CVSS v2.0 Ratings		CVSS v3.x Ratings		CVSS v4.0 Ratings	
Severity	**Severity Score Range**	**Severity**	**Severity Score Range**	**Severity**	**Severity Score Range**
		None*	0.0	None*	0.0
Low	0.0-3.9	Low	0.1-3.9	Low	0.1-3.9
Medium	4.0-6.9	Medium	4.0-6.9	Medium	4.0-6.9
High	7.0-10.0	High	7.0-8.9	High	7.0-8.9
		Critical	9.0-10.0	Critical	9.0-10.0

CVSS vs. CVE

- The main difference between CVSS and CVE lies in their roles. CVE (Common Vulnerability Enumeration) gives unique identifiers to specific security vulnerabilities, making them easier to track.

- CVSS (Common Vulnerability Scoring System) provides a score that shows how severe each CVE is. For example, the Heartbleed vulnerability (CVE-2014-0160) has a CVSS score 7.5, indicating high severity.

Is CVSS a risk score?

- CVSS is not a risk score; it measures the severity of vulnerabilities. While it provides a numerical score indicating the potential impact, it does not account for an exploit's specific context or likelihood.

- CVSS is not a threat model. It is a scoring system that quantifies the severity of vulnerabilities but does not comprehensively analyze threats or their interactions with vulnerabilities.

Vulnerability management & its components

Vulnerability management

- Vulnerability management is a continuous, proactive, and often automated process that keeps your computer systems, networks, and enterprise applications safe from cyber-attacks and data breaches.

- It requires more than scanning and patching.

- *It also requires a 360-degree view of an organization's* systems, processes, and people in order to make informed decisions about the best course of action for detecting and mitigating vulnerabilities.

Vulnerability management components

i) Asset discovery and inventory
IT is responsible for tracking and maintaining records of all devices, software, servers, and more across the company's digital environment, but this can be extremely complex since many organizations have thousands of assets across multiple locations.

ii) Vulnerability scanners
Vulnerability scanners usually work by conducting a series of tests against systems and networks, looking for common weaknesses or flaws. These tests can include attempting to exploit known vulnerabilities, guessing default passwords or user accounts, or simply trying to gain access to restricted areas.

iii) Patch management
Patch management software is a tool that helps organizations keep their computer systems up to date with the latest security patches

iv) Configuration Management
Security Configuration Management (SCM) software helps to ensure that devices are configured in a secure manner, that changes to device security settings are tracked and approved, and that systems are compliant with security policies.

Vulnerability management components

v) Security incident and event management(SIEM)
SIEM software consolidates an organization's security information and events in real time. SIEM solutions are designed to give organizations visibility into everything that's happening across their entire digital estate, including IT infrastructure.

vi) Penetration testing
Penetration testing software is designed to help IT professionals find and exploit vulnerabilities in computer systems. Typically, penetration testing software provides a graphical user interface (GUI) that makes it easy to launch attacks and see the results.

vii) Threat intelligence
Threat protection software provides organizations with the ability to track, monitor, analyze, and prioritize potential threats to better protect themselves. By collecting data from a variety of sources—such as exploit databases and security advisories—these solutions help companies identify trends and patterns that could indicate a future security breach or attack.

viii) Remediation vulnerabilities
Remediation involves prioritizing vulnerabilities, identifying appropriate next steps, and generating remediation tickets so that IT teams can execute on them. Finally, remediation tracking is an important tool for ensuring that the vulnerability or misconfiguration is properly addressed.

Software Patch, its updates and importance

Software patch

- A patch is a software update for an existing application or operating system to resolve bugs (errors) or vulnerabilities.
- A patch is also called a “fix” or “bugfix.”
- For business software or operating systems such as Windows, a special management program is typically used to install patches. Many applications and operating systems have fixed update and patch cycles.
- For example, **Microsoft usually releases patches for its products on the second Tuesday of each month, known as “Patch Tuesday.”** The reason for this is to make it easier for administrators to plan and install updates.
- However, critical security patches are also made available outside the regular update cycle.

Types of Software Patching

Patches can be broadly classified into the following three categories:

- **Security patches:** Security patch management, *i.e.* the process of deploying security patches to address security vulnerabilities in the software, drivers, and other related components helps secure it from being exploited by vulnerabilities and other threat actors.

- **Bug fix patches:** Bugs in software can range in severity from minor to critical. Bug fix patches ensure that the software is up to date with the latest, bug-free version.

- **Feature update patches:** Feature update patches introduce newer features and functions to software. In addition, they also enhance performance, making software faster and more efficient.

Why is patch management important?

Patch management is the process of identifying, testing, deploying, and installing software patches (or updates) to computers.

- **Preventing security breaches:** Software patch management is one of the most important IT tasks in any organization, as patches fix vulnerabilities in the software and applications, keeping cyber-attacks at bay.
- **Ensuring compliance:** With cyber-attacks on the rise, regulatory agencies have taken drastic measures to keep enterprises in line with compliance mandates.
- **Feature updates:** Besides providing security and bug fixes, patches also introduce new features and functions. This improves usability and enhances the end-user experience.
- **Downtime prevention:** Ransomware attacks and other cyber threats not only result in data breaches but can also cause system downtime, which in turn affects the productivity and revenue of any organization.

Conclusion

- With networks becoming more and more complex, it has become critical to actively manage cyber security vulnerabilities.

- Actively managing cyber security vulnerabilities, it is essential to have visibility of internal and third-party network ecosystems.

- IT personnel should learn cyber security to understand more about such vulnerabilities, their impact, and how to fix them.